

安全加固报告 FIX-07: SSTI模板注入

修复漏洞类型: SSTI模板注入

修复小组: 天亮了么

修复时间: 2026-08-26

对应漏洞报告: VULN-07-SSTI模板注入

修复负责人: 蒲云楷

1. 基本信息

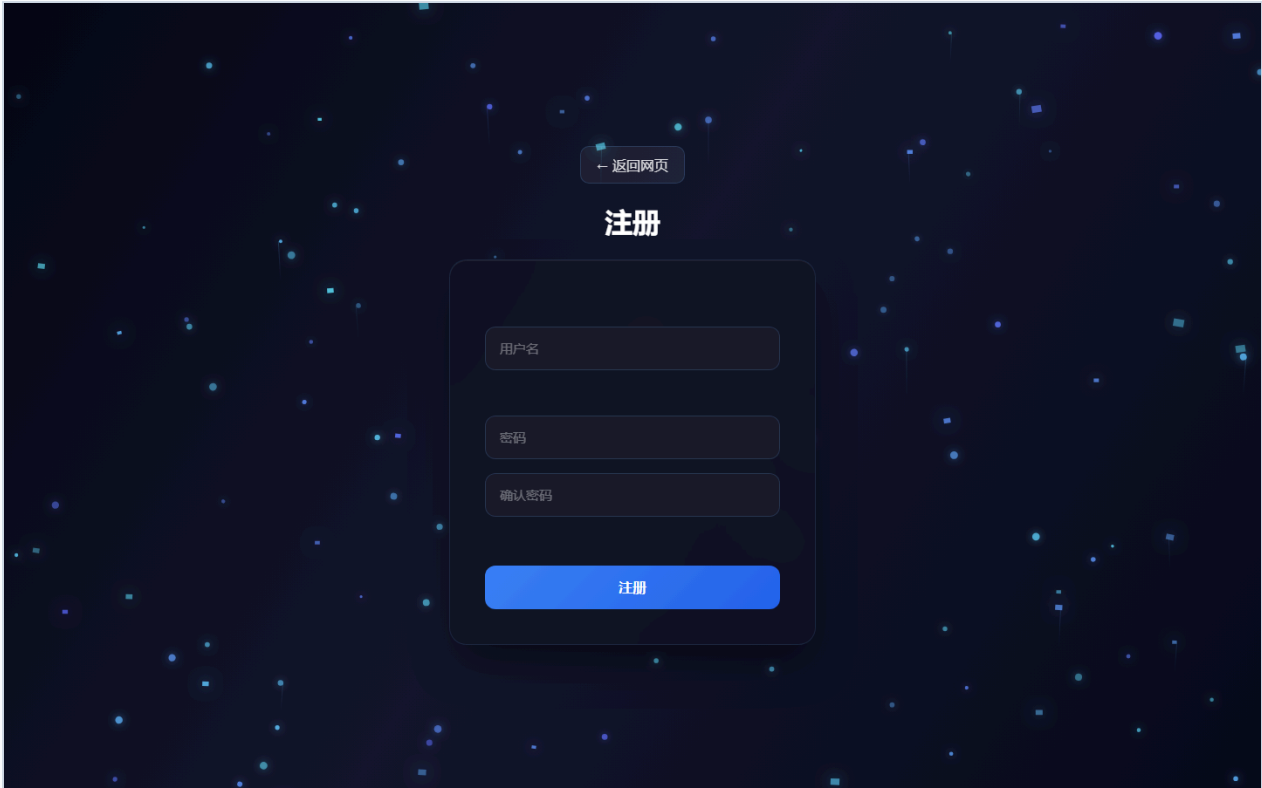
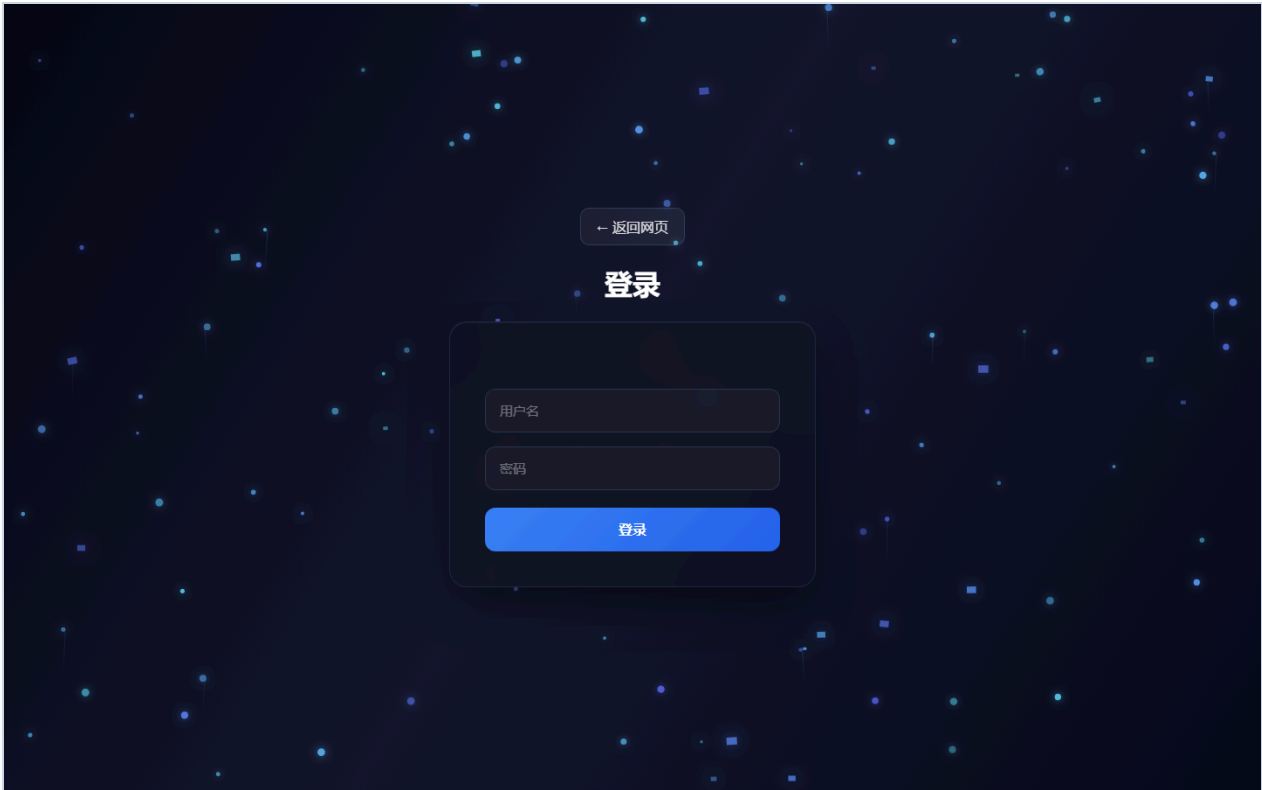
本报告按附录A记录阶段二任务7的修复和验证。

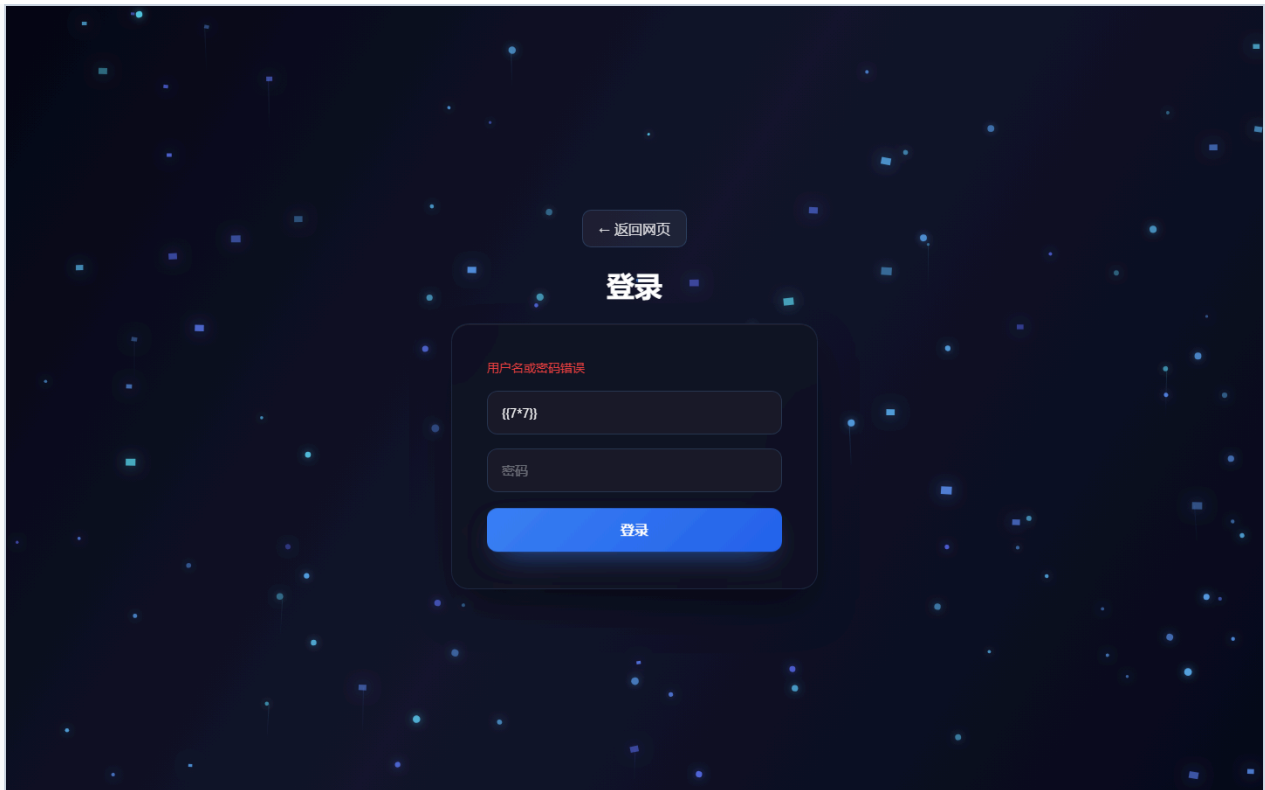
2. 漏洞复现情况

是否能按攻击方步骤复现: 修复前基线已记录; 修复后原始参数应被拦截或不产生越权效果。

复现环境: 本机 127.0.0.1:5001。







修复代码截图（实际源文件与行号）

任务 07 修复代码证据

gets.py:150-180

```
150         "size": stat.st_size,
151         "updated_at": stat.st_mtime,
152     }
153 )
154 return files
155
156
157 @app.get("/")
158 def index():
159     return render_template("webpage.html")
160
161
162 @app.get("/login")
163 def login_page():
164     csrf_token()
165     return render_template("login.html")
166
167
168 @app.post("/login")
169 @csrf_protected
170 def login_post():
171     username = request.form.get("username", "").strip()
172     password = request.form.get("password", "")
173     result = _login(username, password, as_api=False)
174     if isinstance(result, tuple) and len(result) == 2 and isinstance(result[1], int) and result[1] >= 400:
175         return render_template("login.html", error=result[0], username=username), result[1]
176     return result
177
178
179 def _login(username, password, as_api=True):
180     if not username or not password:
```

3. 根因定位

相关文件： gets.py、相关模板和前端 API 客户端。

相关函数或接口： /、/login、/register 可见输入点审计。

问题代码/根因： 未发现 render_template_string 或等价动态模板调用。

4. 修复措施

修改点1

修改文件： gets.py。

修改前逻辑： 缺少统一安全边界或校验。

修改后逻辑： 用户输入只能作为固定模板变量；禁止动态拼接模板。

修改点2

修改文件： 相关 HTML/CSS/前端 API（按任务适用）。

修改后逻辑： 页面和客户端与服务端安全校验保持一致，不能替代服务端校验。

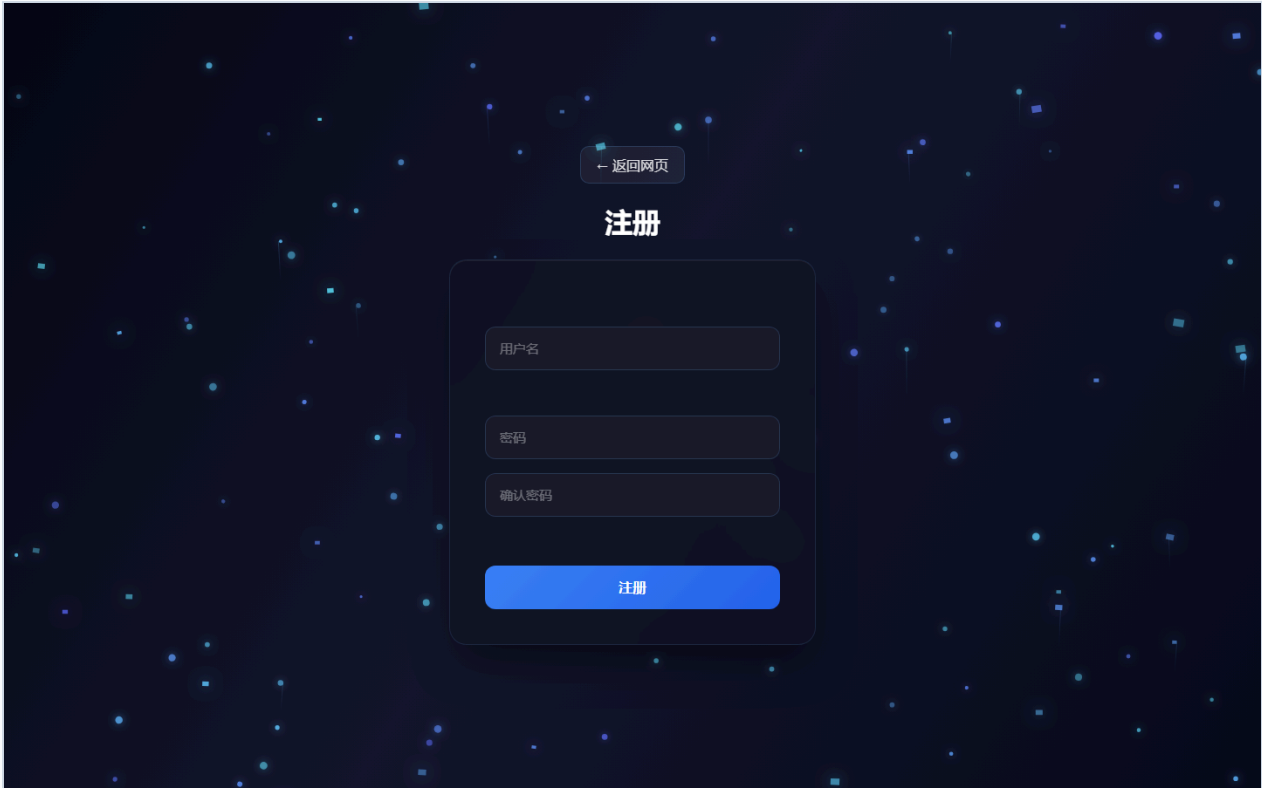
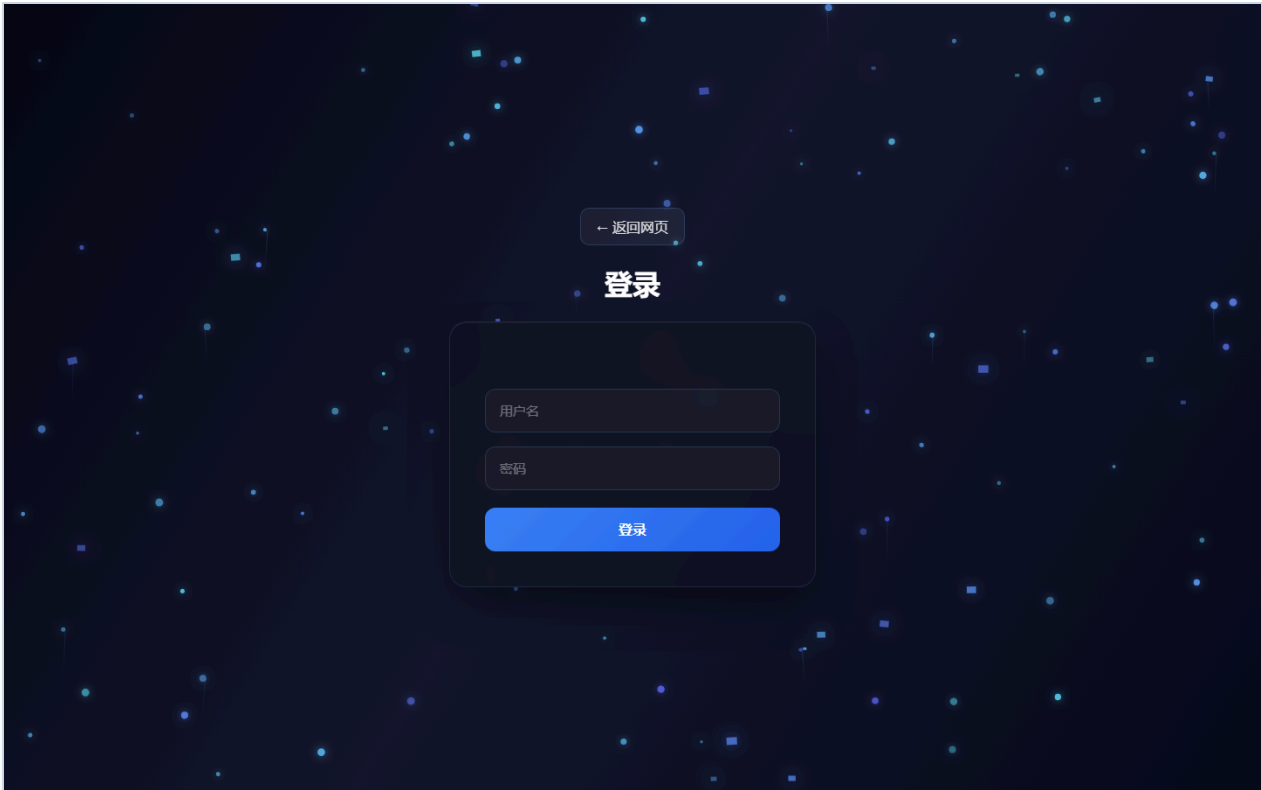
5. 修复后验证

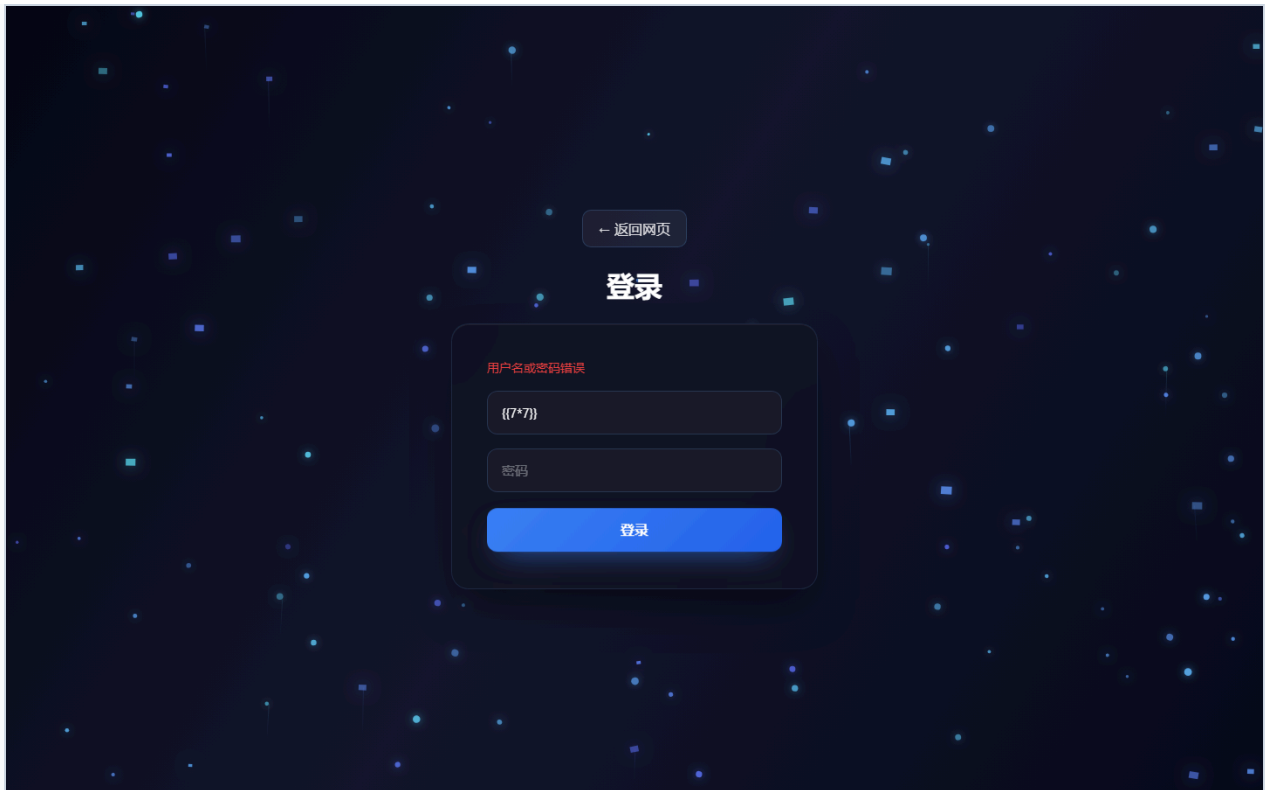
- 使用攻击方原始步骤重新测试：
1. 发送原始无害测试参数。
 2. 观察状态码、页面、数据、文件和日志。
 3. 确认原攻击失效并保存截图。

验证结果：发送 name={{7*7}} 后页面未出现49；未发现用户输入作为模板执行的输入点。

原攻击是否失效：是（本机回归测试）







修复代码截图（实际源文件与行号）

任务 07 修复代码证据

gets.py:150-180

```
150         "size": stat.st_size,
151         "updated_at": stat.st_mtime,
152     }
153 )
154 return files
155
156
157 @app.get("/")
158 def index():
159     return render_template("webpage.html")
160
161
162 @app.get("/login")
163 def login_page():
164     csrf_token()
165     return render_template("login.html")
166
167
168 @app.post("/login")
169 @csrf_protected
170 def login_post():
171     username = request.form.get("username", "").strip()
172     password = request.form.get("password", "")
173     result = _login(username, password, as_api=False)
174     if isinstance(result, tuple) and len(result) == 2 and isinstance(result[1], int) and result[1] >= 400:
175         return render_template("login.html", error=result[0], username=username), result[1]
176     return result
177
178
179 def _login(username, password, as_api=True):
180     if not username or not password:
```

6. 额外加固

统一错误提示、输入长度限制、安全日志、Cookie 安全属性、调试模式关闭和生产密钥配置要求。

7. 仍需改进

课程组别、负责人、Git tag 等元数据需在提交前填写；HTTPS 部署时启用 Secure Cookie；Web 服务器需确认上传目录不可执行。